

บทที่ 2

ทฤษฎีและหลักการที่ใช้ในการพัฒนา

2.1 ทฤษฎีและหลักการของไฟร์วอลล์ (Firewall)

ไฟร์วอลล์เป็นเครื่องมือรักษาความปลอดภัยที่ทำงานในเชิงป้องกันโดยทำหน้าที่ควบคุมการเข้าถึงเน็ตเวิร์ก ซึ่งแพ็คเก็ตที่สามารถผ่านเข้า-ออกเน็ตเวิร์กได้นั้น จะต้องเป็นแพ็คเก็ตที่ไฟร์วอลล์เห็นว่ามีความปลอดภัย โดยอาศัยการเปรียบเทียบคุณสมบัติของแพ็คเก็ตที่จะผ่านไฟร์วอลล์กับกฎที่กำหนดไว้เป็นพื้นฐาน โดยเราสามารถแบ่งชนิดของไฟร์วอลล์ได้หลายประเภทแต่ถ้าจำแนกถึงลักษณะการทำงานของไฟร์วอลล์ที่ใช้ในการตรวจสอบและควบคุม เราสามารถแบ่งไฟร์วอลล์ได้เป็น 3 ประเภท ดังนี้

1. แพ็คเก็ตฟิลเตอร์ริง (Packet Filtering)
2. สเตตฟูลอินสเปกชัน (Stateful Inspection)
3. แอปพลิเคชันพร็อกซี (Application Proxy)

2.1.1 แพ็คเก็ตฟิลเตอร์ริง (Packet Filtering)

เป็นลักษณะการทำงานโดยทั่วไปของไฟร์วอลล์ที่ใช้ควบคุมทราฟฟิกจะอาศัยการตรวจสอบข้อมูลที่ปรากฏอยู่ในแพ็คเก็ตเฮดเดอร์ เช่น แอดเดรสต้นทาง (Source Address) แอดเดรสปลายทาง (Destination Address) พอร์ต (Port) โพรโตคอล (Protocol) เป็นต้น ซึ่งจากข้อมูลเหล่านี้จะสามารถนำมาใช้เป็นเงื่อนไขสำหรับควบคุมการเข้าออกของข้อมูลได้ โดยการพิจารณาข้อมูลทั้งหมดให้เป็นไปตามกฎที่ระบุไว้ ซึ่งเรียกว่า แอ็กเซสรูล (Access Rules) หรือ กฎของการควบคุมการผ่านการเข้าออกของแพ็คเก็ต โดยทั่วไปรูปแบบของแอ็กเซสรูลเบื้องต้นจะเป็นดังนี้

Source Address	Destination Address	Protocol	Service (Dst.Port)	Action
----------------	---------------------	----------	--------------------	--------

ตารางที่ 2.1 แสดงรูปแบบของแอ็กเซสรูลเบื้องต้น

โดยข้อมูลทั้งหมดจะเป็นเสมือนตัวแปรที่จะนำมาเปรียบเทียบกับค่าที่ระบุไว้ในแอ็กเซสรูลทีละค่าเงื่อนไข และในส่วนของฟิลด์สุดท้าย “Action” หมายถึงสิ่งที่ไฟร์วอลล์จะกระทำเมื่อค่าในแพ็คเก็ตนั้นตรงกับเงื่อนไข ตัวอย่างเช่น

Source Address	Destination Address	Protocol	Service (Dst.Port)	Action
ANY	161.246.5.50	TCP	80	ACCEPT

ตารางที่ 2.2 ตัวอย่างของการตั้งค่าแอ็กเซสรูลของไฟร์วอลล์

จากการตั้งแอสคริปต์เช่นนี้จะหมายความว่าไฟร์วอลล์จะอนุญาตให้แพ็กเก็ตที่มีต้นทางหมายเลขไอพีแอสคริปต์ 161.246.5.50 และปลายทางใดๆ ที่ใช้โปรโตคอล TCP หมายเลขพอร์ตปลายทาง 80 ผ่านไฟร์วอลล์ได้ หากไฟร์วอลล์มีแอสคริปต์นี้เพียงข้อเดียว ก็เท่ากับอนุญาตให้โฮสต์เพียงโฮสต์เดียวคือ โฮสต์ที่มีไอพีแอสคริปต์เป็นหมายเลข 161.246.5.50 เท่านั้นที่สามารถใช้บริการ HTTP (TCP พอร์ต 80) ไปยังโฮสต์อื่นที่อยู่อีกฟากหนึ่งของไฟร์วอลล์ได้

2.1.2 สเตตฟูลอินสเปกชัน (Stateful Inspection)

ในการทำงานของไฟร์วอลล์แบบแพ็กเก็ตฟิเตอร์ริงที่ได้กล่าวมานั้น จะเห็นได้ว่าเราสามารถตั้งค่าเพื่อกรองแพ็กเก็ตที่ไม่ต้องการออกไป แต่ไฟร์วอลล์ดังกล่าวยังไม่ปลอดภัยมากพอ เพราะแม้ว่าเราสามารถจำกัดการเชื่อมต่อให้เหลือแค่พอร์ต 80 เท่านั้นที่ติดต่อเข้ามาได้ แต่ไฟร์วอลล์ข้างต้นก็ไม่ได้ตรวจสอบว่า การเชื่อมต่อผ่านพอร์ต 80 นั้นเป็นการเชื่อมต่อตามปกติหรือไม่ คือ หากเป็นพอร์ต 80 แล้วก็จะปล่อยผ่านหมด ทั้งที่อาจเป็นแพ็กเก็ตโจมตีก็ได้ เพราะแฮกเกอร์อาจเทเลเน็ตไปยังพอร์ต 80 เพื่อรันโปรแกรม Backdoor ได้ นอกจากนั้นกรณีที่แพ็กเก็ตที่ผ่านไฟร์วอลล์มาเป็นแพ็กเก็ตที่มีการทำ Fragmentation มาด้วยแล้ว ไฟร์วอลล์ประเภทนี้จะไม่สามารถตรวจสอบอะไรได้เลย

และหากเป็นกรณีที่เป็นการโจมตีโดยการกำหนดแพ็กเก็ตที่ผิดปกติแล้วไฟร์วอลล์แบบแพ็กเก็ตฟิเตอร์ริงจะไม่สามารถตรวจสอบได้เช่นกัน เพราะหากหมายเลขไอพีและพอร์ตผ่านไฟร์วอลล์ประเภทนี้จะยอมให้ผ่านได้ทันที และหากมีการปลอมหมายเลขไอพีแอสคริปต์ด้วยแล้วยังทำให้การป้องกันของไฟร์วอลล์มีความสามารถลดลง นอกจากนั้นสำหรับพอร์ตที่มีหมายเลขมากกว่า 1024 ไฟร์วอลล์ดังกล่าวจะต้องเปิดพอร์ตเหล่านั้นไว้ตลอดเวลา เพราะไฟร์วอลล์ไม่รู้ว่แอปพลิเคชันใดจะใช้งานพอร์ตหมายเลขใดบ้าง ซึ่งถือเป็นความไม่ปลอดภัยอีกเช่นกัน

ซึ่งข้อบกพร่องทั้งหมดนี้ ไฟร์วอลล์แบบสเตตฟูลอินสเปกชัน สามารถป้องกันได้ (ต่อไปจะเรียกว่า สเตตฟูล) โดยไฟร์วอลล์ประเภทนี้จะมีการตั้งกฎขึ้นมาเช่นเดียวกัน แต่ไฟร์วอลล์ประเภทนี้มีความสามารถในการติดตามสถานะการเชื่อมต่อ โดยเฉพาะการเชื่อมต่อแบบ TCP ซึ่งในระหว่างการเชื่อมต่อ ไฟร์วอลล์จะทำการสร้างตารางสถานะ (State Table) ที่จะเก็บสถานะของการเชื่อมต่อในทุก ๆ การเชื่อมต่อเอาไว้ เช่น การเชื่อมต่อในแบบ TCP จะต้องเริ่มด้วย 3 Way Handshake ไฟร์วอลล์สเตตฟูลจึงต้องทำการตรวจสอบว่าแพ็กเก็ตแรกๆ เป็น SYN หรือไม่ และแพ็กเก็ตตอบกลับเป็น SYN/ACK หรือไม่ และแพ็กเก็ตยืนยันเป็น ACK หรือไม่ และยังตรวจสอบอีกว่าแต่ละแพ็กเก็ตมีลำดับของ Sequence Number ถูกต้องหรือไม่ นอกจากในระหว่างการเชื่อมต่อ ไฟร์วอลล์สเตตฟูลยังมีการตรวจสอบหมายเลขลำดับ หมายเลขตอบรับและแฟล็กต่าง ๆ ตลอดเวลา ดังนั้นจะเห็นได้ว่าการสร้างแพ็กเก็ตปลอมปลอมให้ผ่านไฟร์วอลล์แบบสเตตฟูลจะยากขึ้นมาก

สำหรับกรณีของแพ็กเก็ตที่มีการทำ Fragmentation มานั้น ไฟร์วอลล์สเตตฟูลจะรอจนครบทั้ง คาด้าแกรมแล้วจึงทำการจัดเรียงแพ็กเก็ตใหม่ (Reassemble) แล้วจึงตรวจสอบว่าถูกต้องหรือไม่

ดังนั้นการโจมตีโดยวิธีการแบ่งเป็น Fragment ย่อย ๆ เพื่อหลอกไฟร์วอลล์ก็จะทำได้ยากขึ้น และไฟร์วอลล์แบบสเตทฟูลไม่จำเป็นต้องเปิดพอร์ตหมายเลข 1024 ขึ้นไป ทั้งเอาไว้ด้วย เพราะเมื่อไฟร์วอลล์สามารถติดตามสถานะการเชื่อมต่อได้แล้ว ก็ย่อมจะรู้ว่าการเชื่อมต่อนั้น ๆ ฟังไคลเอนต์มีการใช้งานพอร์ตใดเพื่อจะได้เปิดพอร์ตนั้น “เฉพาะ” สำหรับไคลเอนต์ และเมื่อการเชื่อมต่อจบลงก็จะปิดพอร์ตนั้นไว้เหมือนเดิมทำให้ระบบมีความปลอดภัยเพิ่มขึ้นมาก

อย่างไรก็ตามไฟร์วอลล์แบบสเตทฟูลนั้น ไม่ได้ทำงานเหมือนกันไปหมด ไฟร์วอลล์สเตทฟูลบางตัวจะขยับไปทำงานที่ชั้นแอปพลิเคชันในบางโพรโตคอล เช่น ในโพรโตคอล FTP นั้นจะมีการใช้พอร์ต 2 พอร์ต คือ พอร์ต 21 ใช้งานเป็นพอร์ตควบคุม และพอร์ต 20 เป็นพอร์ตข้อมูล ดังนั้นในการทำงานแบบสเตทฟูลนั้น สมมติว่าในครั้งแรกเครื่องไคลเอนต์ 161.246.5.10 ติดต่อมายังพอร์ต 21 ของเซิร์ฟเวอร์ 161.246.4.3 โดยจะส่งค่าพอร์ตฟังไคลเอนต์มาด้วย เช่น 1234 ซึ่งไฟร์วอลล์ก็จะกำหนดในตารางสถานะ (State Table) ว่า ไอพี 161.246.4.3 พอร์ต 21 กับไอพี 161.246.5.10 พอร์ต 1234 มีการเชื่อมต่อกัน หลังจากนั้นไฟร์วอลล์จะเปิดพอร์ตทั้ง 2 เอาไว้ แต่เมื่อมีการส่งข้อมูล เครื่องไคลเอนต์กลับติดต่อมายังพอร์ต 20 ซึ่งไฟร์วอลล์ที่ไม่เข้าใจการทำงานของโพรโตคอล FTP จะบล็อกข้อมูลทำให้ไม่สามารถเชื่อมต่อผ่านพอร์ต 20 เพื่อส่งข้อมูลได้ หรือในการส่งข้อมูลประเภทมัลติมีเดีย เช่น H.323 นั้น พอร์ตควบคุมกับพอร์ตที่ใช้ในการส่งข้อมูลจะเป็นคนละพอร์ต เช่นเดียวกับ FTP และบางครั้งยังเป็นการใช้พอร์ต UDP อีกด้วย ดังนั้นหากไฟร์วอลล์ไม่มีการทำงานในชั้นแอปพลิเคชัน หรือไม่เข้าใจโพรโตคอลนั้น ๆ แล้ว จะทำให้ใช้งานแอปพลิเคชันนั้น ๆ ไม่ได้ หรือหากต้องการจะทำให้ได้ ก็ต้องเปิดพอร์ตนั้นทิ้งเอาไว้ถาวร

สำหรับสเตทฟูลไฟร์วอลล์บางตัวจะสามารถทำงานในชั้นแอปพลิเคชันได้ แต่ยังไม่สามารถป้องกันการโจมตีที่แทรกซึมมากับการเชื่อมต่อตามปกติได้ เช่น โพรโตคอล FTP นั้น แม้ว่าไฟร์วอลล์แบบสเตทฟูลบางตัวจะมีการติดตามให้มีการเปิดพอร์ต 20 และ 21 อย่างถูกต้อง แต่ถ้าหากในเนื้อหาที่ส่งมาเป็นสิ่งที่ประหลาดร้าย ก็จะไม่สามารถรับรู้และป้องกันการโจมตีแบบนี้ได้

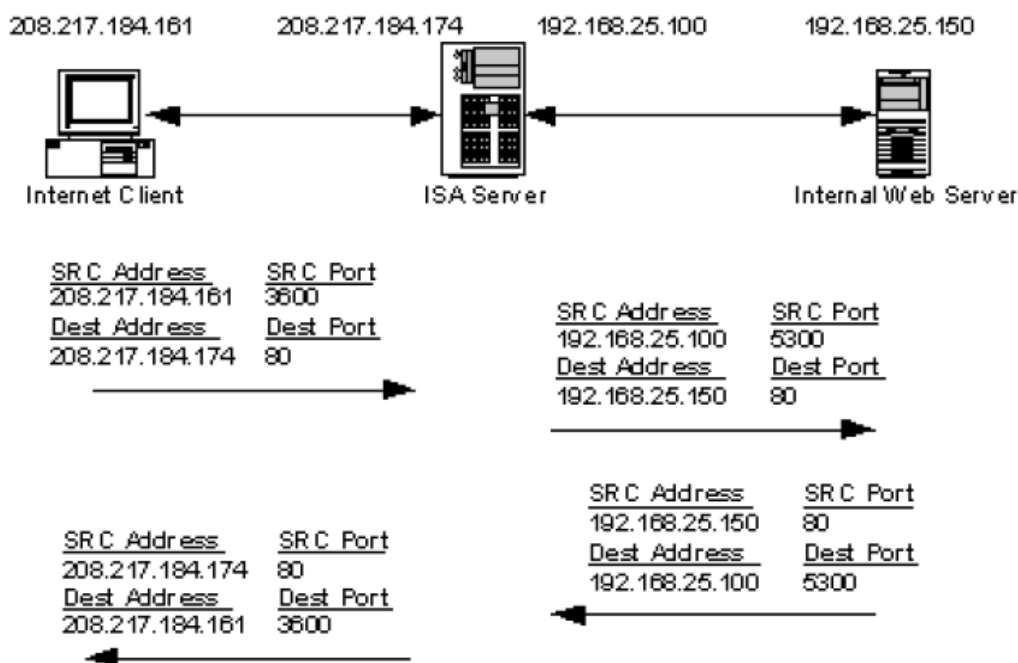
นอกจากนั้นในไฟร์วอลล์หลายตัว จะมีการติดตามสถานะการทำงานของ HTTP เป็นพิเศษ เพราะเป็นที่ทราบกันดีว่าข้อมูลในโลกนี้มีบทบาทของ HTTP อยู่ไม่น้อย และมีการโจมตีผ่านทางเว็บมาก ดังนั้นการติดตามสถานะของ HTTP จะทำให้ระบบเครือข่ายมีความปลอดภัยมากขึ้น

2.1.3 แอปพลิเคชันพร็อกซี (Application Proxy)

แม้ว่าไฟร์วอลล์แบบสเตทฟูลจะมีความปลอดภัยเพิ่มขึ้นมากแล้วก็ตาม แต่ไฟร์วอลล์ประเภทนี้ยังไม่สามารถป้องกันการโจมตีที่แทรกซึมมากับการเชื่อมต่อตามปกติได้ เช่น โพรโตคอล FTP นั้น แม้ว่าไฟร์วอลล์แบบสเตทฟูลจะมีการติดตามให้มีการเปิดพอร์ต 20 และ 21 อย่างถูกต้อง แต่หากมีการส่งข้อมูลอื่น ๆ ที่ไม่ใช่ข้อมูล FTP แทรกมาในระหว่างการเชื่อมต่อ สเตทฟูลไฟร์วอลล์จะไม่รู้ ดังนั้นหากต้องการให้ไฟร์วอลล์มีความสามารถในการติดตามการทำงานของชั้นแอปพลิเคชันมาก

ขึ้นโดยทราบว่าการติดต่อเป็นการติดต่อตามรูปแบบของโพรโตคอลนั้น ๆ อย่างถูกต้องหรือไม่ ไฟร์วอลล์จะต้องก้าวขึ้นไปทำงานในชั้นแอปพลิเคชัน โดยจะเรียกไฟร์วอลล์ชนิดนี้ว่า Application Proxy Firewall

ไฟร์วอลล์ประเภทนี้ จะทำงานในระดับชั้นแอปพลิเคชันเป็นสำคัญ โดยไฟร์วอลล์ประเภทนี้ จะทำหน้าที่เป็นตัวแทน (Proxy) ในการส่งต่อการเชื่อมต่อใด ๆ ไปยังเซิร์ฟเวอร์ เช่น เมื่อไคลเอนต์ 161.246.5.10 ติดต่อไปยังเว็บเซิร์ฟเวอร์ 161.246.4.7 ผ่านทางไฟร์วอลล์ 161.246.5.1 ไฟร์วอลล์ทำหน้าที่รับแพ็กเก็ตที่ขอเชื่อมต่อจาก 161.246.5.10 เอาไว้ จากนั้นจะทำการถอดแพ็กเก็ตเดิมออก แล้วสร้างแพ็กเก็ตใหม่ โดยอาศัยข้อมูลร้องขอเดิมไปยัง 161.246.4.7 เสมือนกับว่าไฟร์วอลล์เป็นผู้ร้องขอเอง ดังนั้นข้อดีประการแรกของไฟร์วอลล์ประเภทนี้ คือ บุคคลภายนอกจะไม่รู้หมายเลขไอพีของเครือข่ายภายในที่ขอเชื่อมต่อออกมาภายนอก และเมื่อเว็บเซิร์ฟเวอร์ตอบกลับก็จะส่งผลลัพธ์กลับไปยังเครื่อง 161.246.5.10



รูปที่ 2.1 แสดงการทำงานของแอปพลิเคชันพร็อกซี

และเนื่องจากทำหน้าที่เป็นตัวแทนในการเชื่อมต่อนี้เอง ทำให้ในการติดต่อผ่านไฟร์วอลล์ทุกครั้ง ไฟร์วอลล์จะทำหน้าที่ในการตรวจสอบรูปแบบการติดต่อว่ามีรูปแบบที่ถูกต้องตามโพรโตคอลนั้น ๆ หรือไม่ ทำให้มีความปลอดภัยเพิ่มขึ้น นอกจากนั้นไฟร์วอลล์แบบนี้ยังป้องกันการปลอมไอพีได้โดยเด็ดขาดเนื่องจากไฟร์วอลล์จะทำหน้าที่ในการส่งต่อเสียเอง แต่การติดต่อแบบนี้ยังมีข้อเสียเช่นกัน คือ ไฟร์วอลล์แบบนี้จะทำงานได้ช้ากว่าเพราะมีการตรวจสอบมากกว่า อีกทั้งยังต้องสร้างแพ็กเก็ตใหม่ในทุก ๆ ครั้งด้วย และหากกรณีที่มีการเชื่อมต่อหนึ่งมีการแบ่งเป็นเซกเมนต์

(Segment) หลาย ๆ เซกเมนต์ ด้วยแล้ว ไฟร์วอลล์ประเภทนี้ต้องรอให้ทุกเซกเมนต์ ส่งมาจนครบก่อน จึงจะส่งต่อได้ ทำให้เกิดความล่าช้าในการทำงานขึ้น นอกจากนั้นการที่ไฟร์วอลล์ประเภทนี้ทำงานในระดับชั้นแอปพลิเคชัน หมายความว่า มันจะส่งต่อเฉพาะโปรโตคอลที่รู้จักเท่านั้น หากโปรโตคอลใดที่ไม่รู้จักจะไม่สามารถส่งต่อได้เลย ในขณะที่หากเป็นไฟร์วอลล์แบบสเตทฟูลแล้ว เราสามารถตั้งค่าให้เปิดพอร์ตต่าง ๆ ทำให้สามารถเชื่อมต่อได้ แต่ไฟร์วอลล์แบบแอปพลิเคชันพรีอ็อกซึ่งจะไม่สามารถติดต่อกับโปรโตคอลนั้น

จากข้อดีของไฟร์วอลล์แบบสเตทฟูลที่มีความรวดเร็วในการทำงาน และข้อดีของไฟร์วอลล์แบบแอปพลิเคชันพรีอ็อกซึ่งมีความปลอดภัยสูงจึงทำให้มีผู้สร้างไฟร์วอลล์ที่ผสมผสานความสามารถของไฟร์วอลล์ทั้งสองขึ้น และเรียกไฟร์วอลล์แบบใหม่นี้ว่า Hybrid Firewall หรือบางผู้ผลิตจะเรียกว่า Adaptive Firewall โดยไฟร์วอลล์แบบใหม่นี้จะแตกต่างกันไปตามผู้ผลิต บางผลิตภัณฑ์ทำงานในแบบพรีอ็อกสำหรับโปรโตคอลหลัก ๆ และแบบสเตทฟูลสำหรับโปรโตคอลทั่ว ๆ ไป บางผลิตภัณฑ์ทำงานในแบบพรีอ็อกในช่วงแรกของการเชื่อมต่อเพราะมีความปลอดภัยสูง และต่อมาหากเชื่อว่าการเชื่อมต่อนั้นเป็นการเชื่อมต่อตามปกติ ก็จะขยับลงมาทำงานในแบบสเตทฟูลเพราะมีความรวดเร็วในการทำงานมากกว่า

ไฟร์วอลล์ในปัจจุบันมีการพัฒนาไปมากจนอาจกล่าวได้ว่าไม่มีผลิตภัณฑ์ไฟร์วอลล์ใด ที่เป็นแบบใดแบบหนึ่ง นอกจากนั้นผลิตภัณฑ์ไฟร์วอลล์มักจะมีการทำงานร่วมกับแอปพลิเคชันด้านความปลอดภัยอื่น ๆ เช่น ทำงานร่วมกับ Antivirus ทำให้ไฟร์วอลล์ส่งข้อมูลของเมลล์ไปตรวจสอบไวรัสก่อนจะส่งต่อ หรือทำงานร่วมกับ IDS เพื่อตรวจสอบการบุกรุก ไฟร์วอลล์บางตัวสามารถตั้งให้ทำงานตามเวลา ตามผู้ใช้ บางตัวสามารถกำหนดกราฟฟิกให้กับแอปพลิเคชันไม่เท่ากันได้ด้วย

2.2 ทฤษฎีและหลักการของฮันนีพอต (Honeypot)

แนวคิดของฮันนีพอตคือ ต้องการทราบการกระทำ และความพยายามต่างๆที่ผู้บุกรุกกระทำต่อระบบ ดังนั้นเพื่อให้ได้มา จำเป็นจะต้องสร้างระบบบางอย่างให้เหล่าผู้บุกรุกได้เข้ามาและระบบต้องสามารถจับตาได้ โดยที่ผู้บุกรุกไม่รู้ตัวว่ากำลังโดนจับตามองอยู่และโดยที่ไม่ส่งผลเสียหายใดๆ ต่อระบบจริง เปรียบเสมือนล่อหลอกให้ขโมยพยายามงัดเข้ามาในบ้าน แล้วใช้กล้องวงจรปิดถ่ายภาพไว้ทุกๆ การกระทำตั้งแต่วิธีที่ใช้ในการงัดเข้ามาในบ้าน พยายามทำอะไรบ้าง สนใจสำรวจอะไรบ้าง หรือได้นำอะไรออกไป โดยที่บ้านและของมีค่าใดๆ เป็นเพียงภาพลวงตาเท่านั้น ทำให้ไม่ต้องเสียทรัพย์สินหรือก่อให้เกิดอันตรายใด ๆ ซึ่งทำให้เราสามารถเห็นวิธีที่ผู้บุกรุกใช้ ตลอดจนเครื่องมือใหม่ๆ ที่ผู้บุกรุกอาจนำมาใช้ ซึ่งเมื่อเราทราบวิธีและเครื่องมือของผู้บุกรุก ทำให้เราสามารถนำข้อมูลที่ได้ไปประยุกต์เพื่อปรับปรุงและป้องกันระบบจริงให้มีความปลอดภัยมากยิ่งขึ้น ตั้งแต่อดีตจนถึงปัจจุบันระบบฮันนีพอตได้มีวิวัฒนาการและการพัฒนาระบบมาตามลำดับ โดยเราสามารถแบ่งชนิดของฮันนีพอตได้ดังต่อไปนี้

2.2.1 ระบบอันนี้พอดแบบ Low-interaction

ในยุคแรกนี้ ระบบอันนี้พอดเป็นเพียงการสร้างบริการเสมือนขึ้นมา (เซิร์ฟเวอร์ที่จำลองขึ้นมาให้เหมือนเซิร์ฟเวอร์จริงๆ) เพื่อจำลองบริการต่างๆ ขึ้นมาให้คุณเสมือนว่ามีเครื่องที่เปิดให้บริการต่างๆ เช่น FTP อยู่เป็นต้น ซึ่งอันนี้พอดชนิดนี้จะมีข้อจำกัดในส่วนของการโต้ตอบการโจมตีของผู้บุกรุก ซึ่งการโต้ตอบของอันนี้พอดรูปแบบนี้จะขึ้นอยู่กับการทำงานจำลองบริการและขึ้นอยู่กับระบบปฏิบัติการที่ใช้ เช่น อาจทำให้สามารถล็อกอินได้ หรือทำให้ใช้คำสั่งต่างๆ ได้เหมือนกับบริการจริงๆ ตัวอย่างอันนี้พอดที่เป็นแบบ Low-interaction เช่น Specter, Honeyd และ KFSensor

ข้อดีของอันนี้พอดแบบนี้อาจมีความยืดหยุ่น ง่ายต่อการเปลี่ยนแปลงและการบำรุงรักษา ตัวอันนี้พอด และมีอัตราเสี่ยงเล็กน้อย ซึ่งโดยทั่วไปแล้วมีระบบ Plug & Play ซึ่งจะทำให้การเปลี่ยนแปลงเป็นไปได้โดยสะดวก การจำลองบริการนั้นจะช่วยลดความเสี่ยงโดยสามารถบรรจุสิ่งที่ผู้ใช้ตอบโต้ผู้บุกรุก ผู้บุกรุกจะไม่สามารถเข้ายึดครองเครื่องอันนี้พอดนั้นเพื่อใช้ในการโจมตีผู้อื่นต่อไปได้

ข้อเสียของอันนี้พอดแบบ Low-interaction นี้คือสามารถออกแบบได้เฉพาะการตรวจจับการกระทำที่ทราบอยู่แล้วเท่านั้น ซึ่งมีข้อจำกัดมากมายในการเฝ้าดูพฤติกรรมผู้บุกรุก เพราะสิ่งที่เห็นจะแค่เพียงส่วนที่เกี่ยวข้องกับบริการนั้นเท่านั้น ไม่เกี่ยวกับเรื่องของระบบปฏิบัติการเลย

2.2.2 ระบบอันนี้พอดแบบ High-interaction

ต่อมาได้มีการสร้างเป็นเครื่องให้บริการเสมือน (เสมือนเป็นเครื่องคอมพิวเตอร์ที่ทำงานจริงซึ่งจะมีเรื่องของระบบปฏิบัติการเข้ามาเกี่ยวข้อง) เรียกระบบอันนี้พอดแบบนี้ว่าเป็นแบบ High-interaction ซึ่งอันนี้พอดแบบนี้จะมีทั้งระบบปฏิบัติการ แอปพลิเคชัน และบริการจริงๆ เพื่อตอบโต้กับผู้บุกรุก นั่นคือถ้าต้องการให้มีบริการใดก็ทำการลงโปรแกรม หรือเปิดบริการต่างๆ ที่เครื่องจริงๆ อย่างเช่น ถ้าจะเปิดบริการ FTP ก็ลงโปรแกรมอย่างเช่น Ftpd เป็นต้น

ข้อดีของอันนี้พอดแบบ High-interaction คือข้อมูลที่ได้จากการกระทำของผู้บุกรุกนั้นมีความครอบคลุมมากกว่าเพราะจะมีการโต้ตอบทุกอย่างที่เหมือนจริง ดังนั้นเราจึงสามารถสรุปผลข้อมูลได้จากการโจมตีจริง ระบบจะตอบโต้กับผู้บุกรุกจริงๆ เราจึงสามารถเรียนรู้ขอบเขตของพฤติกรรมของเหล่าผู้บุกรุกได้ดี และข้อดีอีกข้อหนึ่งคืออันนี้พอดแบบ High-interaction นั้นไม่ได้จำลองการตอบโต้กลับไปยังผู้บุกรุกว่าควรจะตอบกลับแบบใด เพราะใช้เป็นตัวระบบจริงที่ติดตั้งอยู่บนอันนี้พอด สามารถจับตาเหตุการณ์การกระทำต่อระบบซึ่งอาจส่งผลกระทบต่อบริการที่เครื่องนั้นๆ ให้บริการอยู่ หรือข้อมูลที่ผู้บุกรุกสนใจ และทำการสำรวจหรือนำออกไปทำให้สามารถเฝ้าดูพฤติกรรมได้ครอบคลุมกว่าแบบเดิมมาก

ข้อเสียของอันนี้พอดแบบ High-interaction คือการเพิ่มอัตราเสี่ยงให้กับระบบ เนื่องจากผู้บุกรุก อาจจะสามารถเข้ายึดครองเครื่องที่ทำหน้าที่เป็นอันนี้พอด แล้วใช้เครื่องนั้นๆ ในการโจมตีระบบอื่นๆ ก็เป็นไปได้ ดังนั้นการใช้งานอันนี้พอดที่เป็นแบบ High-interaction นั้นจึงต้องหาทาง

ควบคุมพฤติกรรมของผู้บุกรุกให้อยู่ภายในขอบเขตที่เรากำหนดและไม่สามารถใช้ระบบอันนี้เพื่อเป็นฐานที่มั่นในการเข้าโจมตีระบบอื่นๆได้ ตัวอย่างของตัวอันนี้ที่ออกแบบ High-interaction ได้แก่ Honeynets เป็นต้น โดยการกระทำที่สามารถจับตามองได้ในยุคนี้จะเป็นการกระทำที่ไม่มีเรื่องของการเข้ารหัสลับเข้ามาเกี่ยวข้อง เช่นการทำงานผ่าน telnet ซึ่งไม่มีการเข้ารหัสข้อมูลก่อนทำการส่ง ดังนั้นเมื่อมีเทคโนโลยีหรือเครื่องมือใหม่ๆที่มีการเข้ารหัส เช่น SSL, SSH, SCP ก็จะไม่สามารถดักข้อมูลได้

ต่อมาได้มีการนำเครื่องมือที่มีลักษณะของ Rootkits ซึ่งมีการทำงานแบบ Kernel-base tools เข้ามาใช้งานเพื่อให้สามารถเข้าถึงข้อมูลทำการเข้ารหัส โดยที่เครื่องมือเหล่านี้ไม่ได้ไปนำข้อมูลมาถอดรหัส แต่จะเป็นการดูข้อมูลก่อนที่จะถูกเข้ารหัส(กรณีที่เป็นฝั่งส่ง) และอ่านข้อมูลหลังจากที่ถอดรหัสเรียบร้อยแล้ว (ในฝั่งรับ) ทำให้สามารถจับตามองการกระทำของผู้บุกรุกได้ แม้จะใช้ SSH เข้ามายังเครื่องกับดัก ดังนั้นสิ่งที่เราสามารถบันทึกได้จะครอบคลุมพฤติกรรมของผู้บุกรุกทั้งหมด เช่น การกด keyboard การใช้คำสั่ง การถ่ายโอนไฟล์ การนำข้อมูลเข้าออก หรือการเรียกใช้โปรแกรม อีกทั้งระบบยังได้มีการเพิ่มคุณสมบัติในการซ่อนตัวเองไม่ให้ผู้บุกรุกตรวจพบที่กำลังทำงานอยู่ และในยุคนี้ได้เริ่มนำอันนี้พอดเข้ามาเป็นส่วนหนึ่งของระบบจริง นั่นคือมีการทำการคัดแยกผู้บุกรุกออกจากผู้ใช้งานทั่วไป โดยประกอบขึ้นด้วยหลายๆส่วน ซึ่งทำหน้าที่ต่างกันไป เช่น Honeywall, Log server, Cage ซึ่งเครื่องกับดักนั้นจะถูกแยกออกจากเครื่องให้บริการจริง เพื่อไม่ให้เกิดการกระทำต่อเครื่องกับดักเกิดความเสียหายต่อเครื่องให้บริการจริง

2.3 ความรู้พื้นฐานเกี่ยวกับการบุกรุก

ประเภทของผู้บุกรุก

- ผู้บุกรุกจากภายนอก (Outsider intruder) หมายถึง บุคคลภายนอกเครือข่ายที่พยายามเจาะเข้ามาในระบบหรือพยายามโจมตีระบบจากภายนอก เช่น การเจาะเข้ามายังเครื่องเว็บเซิร์ฟเวอร์แล้วเปลี่ยนหน้าเว็บไซต์ของเรา เป็นต้น ซึ่งการบุกรุกนี้อาจมาจากอินเทอร์เน็ต, การ dial-up หรือการบุกเข้าไปยังเครือข่ายของคู่ค้าแล้วเชื่อมต่อมายังเครือข่ายของเรา
- ผู้บุกรุกจากภายใน (Insider intruder) บุคคลภายในเครือข่าย รวมทั้งผู้ใช้ที่ใช้สิทธิ์ในทางที่ผิด หรือการลักลอบใช้สิทธิ์ของผู้ใช้คนอื่นๆ ที่มีสิทธิ์เหนือกว่า

ประเภทของการบุกรุก

- การบุกรุกทางกายภาพ (Physical Intrusion) ผู้บุกรุกพยายามบุกรุกที่เครื่องโดยตรง อาจเข้ามาใช้สิทธิ์พิเศษจากการทำงานที่คอนโซล หรือถอดย้ายอุปกรณ์ เช่น ฮาร์ดดิสก์ ซึ่งอาจนำไปเขียนหรืออ่านภายหลัง หรือบายพาสไปออสได้

- การบุกรุกทางระบบ (System Intrusion) ผู้บุกรุกที่เข้ามาในระบบ โดยปกติมักเป็นผู้ใช้ที่มีสิทธิ์ต่ำ ถ้าระบบไม่ได้ใส่แพตช์ (patch) ที่สามารถแก้ช่องโหว่ของแอปพลิเคชันแล้ว จุดนี้อาจจะเป็นช่องโหว่ที่ทำให้ผู้ใช้คนนั้นสร้างสิทธิ์ของตัวเองให้มากขึ้น จนเทียบเท่าผู้ดูแลระบบได้ เนื่องจากแอปพลิเคชันที่ใช้งานเกือบทุกอย่างมีช่องโหว่อยู่ ถ้ายังไม่สามารถทำให้ช่องโหว่นั้นหมดไปหรือลดลงได้ จุดนี้จะกลายเป็นช่องทางสำหรับการบุกรุกระบบ
- การบุกรุกระยะไกล (Remote Intrusion) ผู้บุกรุกติดต่อผ่านทางเน็ตเวิร์ก มีหลายเทคนิคในการบุกรุกระบบแบบนี้ ปัจจุบันมีแอปพลิเคชันประเภทไฟร์วอลล์ (Firewall) ทำหน้าที่เป็นด่านแรกในการป้องกันการบุกรุกทางเน็ตเวิร์ก

ตัวอย่างการบุกรุก

- Non-blind spoofing เป็นการโจมตีที่เกิดขึ้นได้เมื่อผู้บุกรุกอยู่บนชั้นเน็ตเดียวกันกับเครื่องเป้าหมายซึ่งผู้บุกรุกสามารถมองเห็นลำดับของหมายเลขลำดับ (Sequence number) และ acknowledgement ของแพ็คเก็ตต่างๆได้ เมื่อผู้บุกรุกรู้ลำดับของแพ็คเก็ตซึ่งอาจทำได้โดยใช้โปรแกรมดักจับแพ็คเก็ตที่วิ่งไปมาอยู่ในเครือข่ายแล้วนำมาพิจารณาแล้ว ผู้บุกรุกสามารถทำ session hijacking ได้จากนั้นผู้บุกรุกจะทำการดักเอาส่วนของการยืนยันตนต่างๆ ที่ใช้ในการสถาปนาการเชื่อมต่อไว้ ทำให้การสถาปนาเชื่อมต่อที่ล้มเหลว จากนั้นจึงทำการสถาปนาการเชื่อมต่อใหม่โดยการแก้ไข sequence number และ acknowledgement number ให้ตรงกับเครื่องของผู้บุกรุกก็จะถือว่าการโจมตีนี้ทำได้สำเร็จ
- Blind spoofing เป็นการโจมตีที่เกิดขึ้นจากภายนอกซึ่งผู้บุกรุกไม่อาจรู้ลำดับ sequence และ acknowledgement ดังนั้นผู้บุกรุกจึงพยายามส่งแพ็คเก็ตจำนวนมากไปยังเครื่องเป้าหมายอย่างสม่ำเสมอ ตามลำดับของหมายเลขลำดับ (Sequence number) ที่ส่งขึ้นมา แต่ในปัจจุบันนี้ระบบปฏิบัติการได้มีการพัฒนาเรื่องของการสุ่มหมายเลขลำดับ ทำให้การคาดเดาให้ถูกต้องนั้นเป็นไปได้ยาก แต่ถึงอย่างไรก็ตามถ้าหมายเลขลำดับ ที่ผู้บุกรุกสุ่มขึ้นมานั้นถูกต้อง ข้อมูลจากเครื่องผู้บุกรุกก็จะถูกส่งไปยังเครื่องเป้าหมายเช่นกัน
- Man in the Middle Attack เรียกได้อีกอย่างหนึ่งว่า connection hijacking ซึ่งการโจมตีแบบนี้จะเป็นการเข้าไปขัดขวางการสื่อสารระหว่างเครื่องโฮสต์ 2 เครื่องและเข้าควบคุมการสื่อสารเพื่อสับเปลี่ยนแก้ไข หรือเพิ่มข้อมูลที่เครื่องทั้ง 2 ส่งถึงกันได้ โดยที่ผู้บุกรุกจะทำเช่นนี้ได้ผู้บุกรุกเองต้องอยู่ในสถานที่เดียวกับเครื่องทั้ง 2 เครื่องที่ติดต่อกันโดยหัวใจหลักของการโจมตีแบบนี้คือการทำให้การติดต่อระหว่างเครื่องโฮสต์อยู่ในสถานะที่เรียกว่า “desynchronized” นั่นคือการทำให้เลขลำดับ sequence ของแพ็คเก็ตที่ได้รับไม่ตรงกับเลขลำดับลำดับที่ต้องการนั่นเอง

- Denial of Service Attack คือ IP spoofing ที่ใช้บ่อยที่สุด ในการโจมตีแบบ denial of service หรือ DoS ผู้บุกรุกจะทำการใช้แบนด์วิดท์และทรัพยากรเครือข่ายให้หมดไปโดยการส่งแพ็กเก็ตจำนวนมากเท่าที่จะทำได้ไปยังเครื่องเป้าหมายในเวลาอันสั้น โดยผู้บุกรุกจะทำการเปลี่ยนไอพีต้นทางไปเรื่อยเพื่อทำให้การหยุดDoSทำได้ยากยิ่งขึ้น

2.4 ระบบตรวจจับผู้บุกรุกผ่านเครือข่าย (NIDS)

ระบบตรวจจับผู้บุกรุกทางเครือข่าย (Network Intrusion Detection System : NIDS) เป็นระบบตรวจจับแพ็กเก็ตที่วิ่งอยู่ในเครือข่ายโดยพยายามตรวจสอบว่ามีผู้บุกรุกพยายามบุกรุกเข้าสู่ระบบหรือไม่ ตัวอย่างของระบบนี้ เช่น ระบบที่ตรวจสอบว่ามีแพ็กเก็ตของการเชื่อมต่อแบบทีซีพี/ไอพี (TCP/IP) ชื่อว่า SYN ส่งเข้ามายังระบบเป็นจำนวนมากอย่างผิดปกติในเครื่องเป้าหมายหรือไม่ ซึ่งการกระทำแบบนี้สามารถวิเคราะห์ได้ว่ามีผู้บุกรุกพยายามสแกนพอร์ตทีซีพี (TCP port) ของเครื่องอยู่ ระบบตรวจจับผู้บุกรุกทางเน็ตเวิร์กสามารถทำงานที่เครื่องเป้าหมาย หรือเครื่องที่ทำหน้าที่เฉพาะที่ใช้ในการเฝ้าดูเหตุการณ์ไม่ปกติในเครือข่ายก็ได้ ดังนั้นระบบตรวจจับผู้บุกรุกทางเครือข่ายสามารถตรวจสอบเครื่องใด ๆ ก็ได้ในเครือข่าย

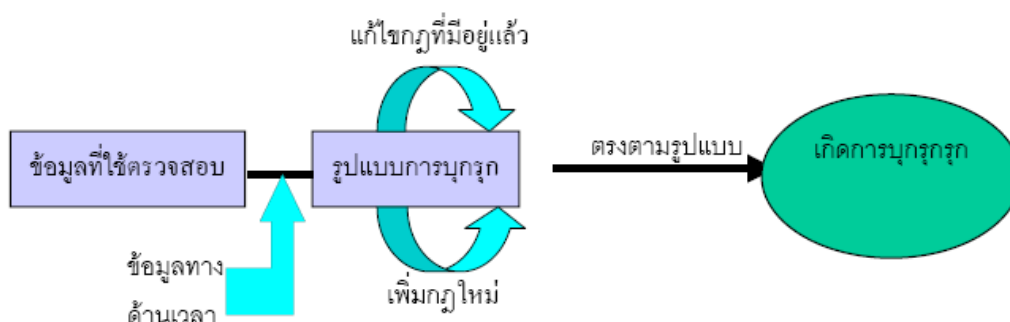
ระบบตรวจจับผู้บุกรุกมีหลักการทำงานต่างไปจากไฟร์วอลล์ คือในขณะที่ไฟร์วอลล์ทำหน้าที่กรองแพ็กเก็ต แต่ NIDS จะทำหน้าที่ตรวจสอบแพ็กเก็ต หรือถ้าจะเปรียบว่าระบบคอมพิวเตอร์คือบ้านหลังหนึ่ง ไฟร์วอลล์จะทำหน้าที่เป็นเซฟที่จะเปิดให้เฉพาะผู้ที่ได้รับอนุญาต ในขณะที่ NIDS จะทำหน้าที่เป็นอุปกรณ์ตรวจจับการบุกรุก ซึ่งหากขโมยเข้ามาในบ้าน ไฟร์วอลล์จะไม่ทราบว่าขโมยเข้ามา หากเซฟนั้นสร้างมาดีพอสิ่งที่อยู่ในเซฟก็จะปลอดภัย แต่หากเซฟสร้างมาไม่ดี หรือขโมยมีความเก่งกาจมาก ๆ ก็อาจจะเปิดเซฟออกมาได้ แต่หากบ้านของคุณมีอุปกรณ์ตรวจจับการบุกรุกแล้ว คุณก็จะทราบได้ก่อนว่าขณะนี้เซฟกำลังถูกแกะอยู่ ซึ่งทำให้คุณสามารถหาทางรับมือหรือหาทางป้องกันได้อย่างทันทั่วทั้งนี้ คือหน้าที่ของ NIDS ซึ่งจะเป็นเครื่องมือที่ช่วยเสริมการทำงานของไฟร์วอลล์ได้เป็นอย่างดี โดยไฟร์วอลล์จะเน้นการทำงานแบบตั้งรับ แต่ NIDS จะเน้นการทำงานในเชิงรุกซึ่งจะทำให้ระบบมีความปลอดภัยสูงขึ้น

โปรแกรม NIDS ถือได้ว่าเป็นโปรแกรมที่มีความซับซ้อนมาก ทั้งนี้เนื่องจากโปรแกรม NIDS ที่ดีจะต้องเป็นโปรแกรมที่มีความฉลาด เพราะจะต้องตรวจสอบแพ็กเก็ตที่วิ่งไปมาในระบบเครือข่าย เพื่อหาแพ็กเก็ตที่มีลักษณะไม่ปกติ นอกจากนั้นยังจะต้องวิเคราะห์อีกด้วยว่า ความไม่ปกตินั้นเป็นความพยายามที่จะเจาะระบบหรือไม่

2.4.1 วิธีการตรวจจับผู้บุกรุกของ NIDS

- วิธีเปรียบเทียบพฤติกรรมผู้ใช้กับรูปแบบการบุกรุกที่รู้จัก (Misuse Intrusion Detection)

วิธีนี้ทำการตรวจจับการบุกรุกที่อยู่ในรูปแบบที่รู้จัก หลักสำคัญของการตรวจจับวิธีนี้คือต้องระบุถึงสัญญาณการเกิดการบุกรุกทั้งหมดที่เป็นไปได้



รูปที่ 2.2 การทำงานของระบบตรวจจับผู้บุกรุกโดยวิธีเปรียบเทียบพฤติกรรมผู้ใช้กับรูปแบบการบุกรุกที่รู้จัก

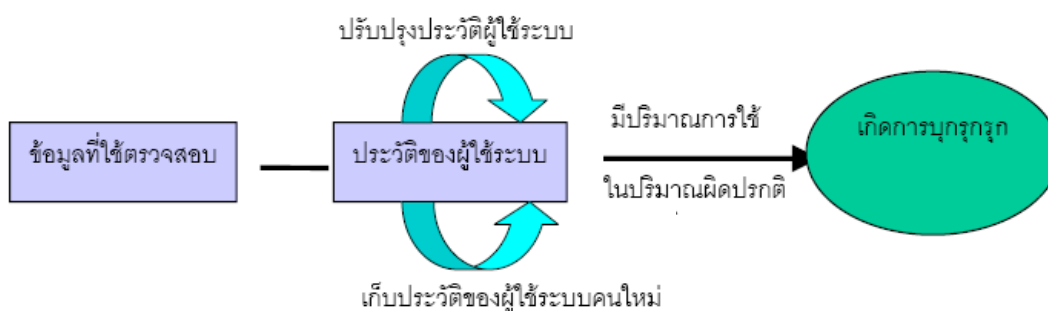
จากรูป ข้อมูลที่ใช้ตรวจสอบถูกนำมาเปรียบเทียบกับกฎ (Rules) ที่มีอยู่ ซึ่งมีการนำข้อมูลทางเวลาเข้ามาพิจารณาด้วย การตรวจจับการบุกรุกโดยวิธีนี้สามารถมีการแก้ไขกฎหรือเพิ่มกฎได้ในระบบที่เป็นปัญญาประดิษฐ์ ระบบอาจทำการแก้ไขกฎหรือเพิ่มกฎได้ด้วยตัวเอง

จุดอ่อนของวิธีการเปรียบเทียบพฤติกรรมผู้ใช้กับวิธีการบุกรุกที่ระบบรู้จักนั้นคือ

1. ประสิทธิภาพในการตรวจจับผู้บุกรุกนั้นจะขึ้นอยู่กับทางเลือกใช้กฎที่ใช้เปรียบเทียบ
2. หากตั้งกฎได้ไม่รัดกุมพอ เมื่อผู้ใช้ปกติทำพฤติกรรมที่ตรงกับกฎของระบบตรวจจับผู้บุกรุกโดยไม่ได้ตั้งใจระบบตรวจจับอาจเข้าใจผิดว่าผู้ใช้นั้นๆ เป็นผู้บุกรุกได้
3. รูปแบบการบุกรุกที่ไม่รู้จักจะไม่สามารถถูกตรวจพบได้

- วิธีตรวจสอบการใช้งานทรัพยากรระบบที่ผิดปกติ (Anomaly Intrusion Detection)

วิธีตรวจจับการบุกรุกโดยตรวจสอบการใช้งานทรัพยากรระบบที่ผิดปกตินี้ตั้งอยู่บนสมมติฐานที่ว่ากระทำการใด ๆ ที่เป็นการบุกรุกจะต้องมีการใช้งานทรัพยากรระบบอย่างผิดปกติ หมายความว่าในการตรวจจับวิธีนี้ต้องมีการเก็บพฤติกรรมปกติของผู้ใช้ระบบไว้ เพื่อเปรียบเทียบว่าพฤติกรรมใดเป็นพฤติกรรมที่ผิดปกติ การเปรียบเทียบจะใช้สถิติศาสตร์เข้ามาช่วย ดังแสดงในรูป



รูปที่ 2.2 การทำงานของการตรวจจับผู้บุกรุกโดยวิธีตรวจสอบการใช้งานระบบที่ผิดปกติ

ข้อมูลที่ใช้ตรวจสอบ (Audit data) ซึ่งเก็บบันทึกโดยระบบจะถูกนำมาปรับปรุงไฟล์ประวัติ (Profile) ของผู้ใช้ พร้อมกันนั้นจะนำข้อมูลนี้มาเปรียบเทียบกับสถิติการใช้งานของผู้ใช้แต่ละคน หากพบว่ามีค่าผิดไปจากค่าปกติก็จะระบุว่าอยู่ในสถานะที่มีการบุกรุกเกิดขึ้น นอกจากนี้ถ้ามีการตรวจสอบโดยใช้ข้อมูลใหม่ ๆ ก็สามารถเพิ่มในไฟล์ประวัติได้

ในการตรวจจับของ NIDS ส่วนใหญ่ เนื่องจากการตรวจจับเป็นการตรวจจับทางเครือข่าย ซึ่งข้อมูลจะอยู่ในรูปของแพ็กเก็ต จึงมักจะใช้วิธีการ Misuse กล่าวคือ ตรวจสอบรูปแบบการโจมตีโดยตรง โดยอาจเรียกรูปแบบการโจมตีว่า Pattern Attack หรือบางครั้งอาจเรียกว่า Signature โดยตัวอย่างข้างต้นนี้เป็นรูปแบบของการตรวจสอบการโจมตีของ Nimda (เป็นหนึ่งในหลาย ๆ บรรทัดของสคริปต์ที่ใช้โจมตี)

GET /script/...%c%af../winnt/system32/cmd.exe?/c+dir

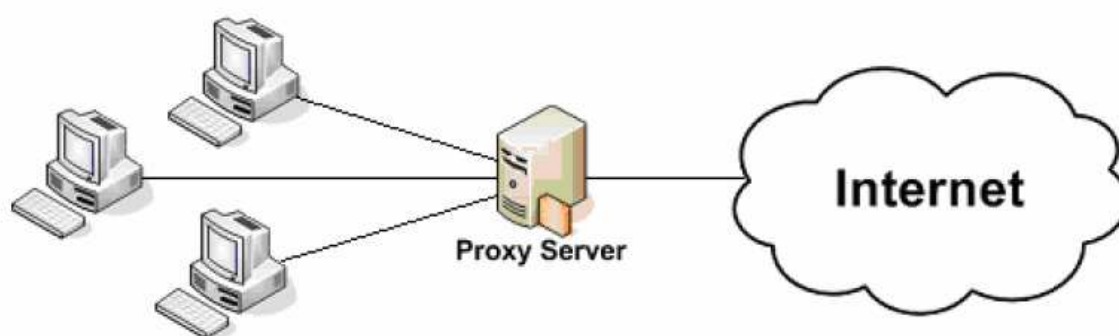
โดย %c%af เป็นข้อมูลที่เป็น Unicode ที่มีความหมายเท่ากับเครื่องหมาย Slash ดังนั้นคำสั่งข้างต้นจึงเป็นคำสั่งที่สั่งให้วิ่งไปที่ Root Directory แล้วเรียกโปรแกรมใน /winnt/system32/cmd.exe เพื่อโจมตีจุดอ่อนของระบบ ดังนั้นเราจึงสามารถสร้างรูปแบบการตรวจสอบได้ว่าข้อมูลในแพ็กเก็ตนี้เป็นการโจมตีของ Nimda ซึ่งข้างต้นนี้เป็นรูปแบบการโจมตีแบบง่าย ๆ โดยในการโจมตีบางครั้งอาจมีความซับซ้อนมากกว่านี้ ซึ่งรูปแบบของการตรวจสอบการโจมตีก็จะต้องซับซ้อนมากขึ้นตามไปด้วย

การใช้วิธีตรวจจับการโจมตีโดย Signature นี้มีข้อดีที่มีความแม่นยำสูง และสามารถ อัปเดตไฟล์ Signature ให้มีความทันสมัยได้เรื่อย ๆ ซึ่งต่างจากวิธีการ Anomaly ซึ่งไม่แม่นยำ อย่างไรก็ตาม เนื่องจากการสร้างรูปแบบให้มีความจำเพาะเจาะจงลงไปถึงการโจมตีเป็นเรื่องยาก ดังนั้นในบางครั้งอาจมีการตรวจพบว่าเป็นการโจมตีจากข้อมูลทั่วไป ซึ่งจะเรียกการตรวจจับที่ผิดพลาดในลักษณะนี้ว่า False Negative และในบางครั้งเมื่อผู้โจมตีมีการปรับเปลี่ยนสคริปต์การโจมตีเพียงเล็กน้อยก็สามารถผ่านการตรวจสอบไปได้ ซึ่งจะเรียกกรณีแบบนี้ว่า False Positive

2.5 พร็อกซี

2.5.1 เว็บพร็อกซี (Regular Webproxy)

เว็บพร็อกซีมีลักษณะการใช้งานคือ การอนุญาตให้เครื่องไคลเอนต์ภายในเครือข่ายสามารถติดต่อกับอินเทอร์เน็ตได้โดยผ่านเว็บพร็อกซี โดยเว็บพร็อกซีจะรอรับการร้องขอจากเครื่องไคลเอนต์ภายในเครือข่าย แล้วทำการส่งต่อการร้องขอนี้ไปยังเครื่องเซิร์ฟเวอร์ จากนั้นจึงรอรับการตอบกลับมาจากเซิร์ฟเวอร์แล้วทำการส่งต่อการตอบรับนั้นให้กับไคลเอนต์ ซึ่งเว็บพร็อกซีนี้สามารถทำการแคชข้อมูล คือการเก็บสำเนาข้อมูลจากอินเทอร์เน็ตมาไว้ที่เว็บพร็อกซี ทำให้เว็บพร็อกซีนั้นไม่ต้องทำการร้องขอข้อมูลที่เคยทำการการร้องขอไปแล้วซ้ำ สามารถที่จะส่งข้อมูลเหล่านั้นให้กับเครื่องไคลเอนต์ที่ทำการร้องขอข้อมูลได้ทันที ทำให้การใช้งานอินเทอร์เน็ตนั้นทำได้รวดเร็วมากขึ้น



รูปที่ 2.3 แสดงตำแหน่งของเว็บพร็อกซีในเครือข่าย

ความสามารถและการใช้งานเว็บพร็อกซี

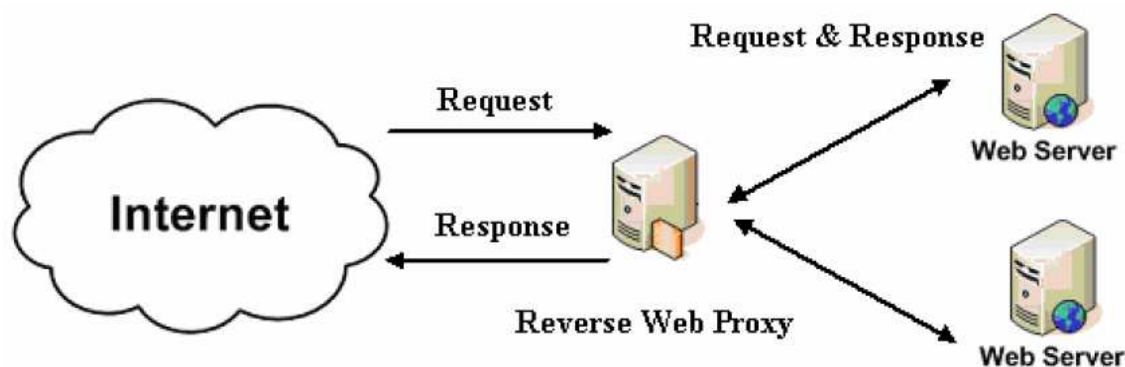
1. อนุญาตและจำกัดการใช้งานอินเทอร์เน็ตของเครื่องไคลเอนต์โดยวิธีการตรวจสอบไอพีแอดเดรส
2. แคชข้อมูลจากภายนอกให้เครื่องภายในเครือข่ายที่ต้องการข้อมูลที่เหมือนกันเรียกใช้งานได้เร็วขึ้น สามารถควบคุมให้การเข้าใช้งานอินเทอร์เน็ตและเซิร์ฟเวอร์ที่ต้องการได้โดยกำหนด URL เป็นหลัก
3. อนุญาตหรือปฏิเสธการร้องขอจากไคลเอนต์โดยมีรูปแบบเงื่อนไขในการตัดสินใจ
4. กำหนด URL ที่จะใช้ในการกรองหรืออนุญาตให้เรียกใช้ผ่านเครื่องเซิร์ฟเวอร์ได้

2.5.2 รีเวิร์สเว็บพร็อกซี (Reverse Webproxy)

รีเวิร์สเว็บพร็อกซี เป็นพร็อกซีที่ทำงานบนฝั่งเซิร์ฟเวอร์แทนที่จะทำงานบนฝั่งไคลเอนต์จึงเรียกว่าเป็นการทำงานแบบรีเวิร์ส รีเวิร์สเว็บพร็อกซีเป็นแอปพลิเคชันพร็อกซีสำหรับเซิร์ฟเวอร์ที่ใช้โปรโตคอล HTTP รีเวิร์สเว็บพร็อกซีจะทำงานอยู่ระหว่างไคลเอนต์กับเว็บเซิร์ฟเวอร์ทำหน้าที่

เป็นเกตเวย์ของเว็บเซิร์ฟเวอร์ หรือ ไอพีแอดเดรสที่ใช้สำหรับรับการร้องขอจากภายนอก ทำให้ไคลเอนต์เห็นรีเวิร์สเว็บพรีอกซ์เป็นเครื่องเว็บเซิร์ฟเวอร์ และทำหน้าที่ดูแลกราฟิกก่อนที่จะเข้าถึงเว็บเซิร์ฟเวอร์ โดยตรวจสอบการร้องขอที่ส่งเข้ามานั้นว่าเคยมีการแคชไว้หรือไม่ถ้ามีอยู่ในแคชก็จะทำการตอบกลับข้อมูลในแคชให้กับไคลเอนต์ ทำให้เว็บเซิร์ฟเวอร์ไม่ต้องสร้างข้อมูลตอบกลับหรือผลลัพธ์ทุกครั้งที่ได้รับการร้องขอ เว้นแต่ข้อมูลประเภท Dynamic ที่จะต้องมีการส่งการร้องขอไปยังเว็บเซิร์ฟเวอร์เพื่อประมวลผลทุกครั้ง โดยก่อนใช้งานรีเวิร์สเว็บพรีอกซ์ต้องมีการกำหนด prefix mapping ให้แกรีเวิร์สเว็บพรีอกซ์ก่อนซึ่ง prefix mapping มี 2 ชนิด คือ

- 1) regular mapping ใช้สำหรับบอกรีเวิร์สเว็บพรีอกซ์ว่า URL prefix ไหนถูกแทนที่และบอก URL ปลายทางจริง
- 2) reverse mapping เป็นส่วนแปลง URL prefix ไปเป็น URL ของรีเวิร์สเว็บพรีอกซ์ซึ่งเป็นชื่อเว็บเซิร์ฟเวอร์จริงที่ใช้ในการติดต่อสื่อสารกับไคลเอนต์

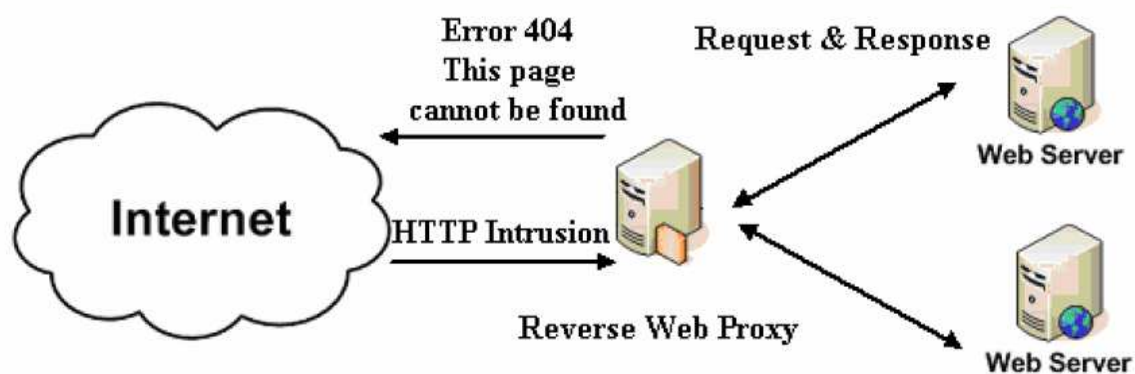


รูปที่ 2.4 การทำงานของรีเวิร์สเว็บพรีอกซ์

ในการใช้งานรีเวิร์สเว็บพรีอกซ์นั้นจะมีการใช้งานร่วมกับไฟร์วอลล์โดยมีการกำหนดกฎให้มีเพียงแต่ไอพีแอดเดรสของรีเวิร์สเว็บพรีอกซ์เท่านั้นที่สามารถติดต่อกับเว็บเซิร์ฟเวอร์ได้ ซึ่งหากมีการติดต่อสื่อสารเป็นการร้องขอจากไคลเอนต์มายัง URL ของรีเวิร์สเว็บพรีอกซ์ซึ่งเป็นทางที่ใช้ในการติดต่อกับเว็บเซิร์ฟเวอร์ รีเวิร์สเว็บพรีอกซ์ก็จะทำการตรวจสอบการร้องขอนั้นกับ prefix mapping ว่าจะต้องส่งการร้องขอนั้นให้กับเว็บเซิร์ฟเวอร์ใด จากนั้นจึงจะส่งการร้องขอนั้นไปยังไฟร์วอลล์เพื่อทำการส่งการร้องขอนั้นให้กับเว็บเซิร์ฟเวอร์ ทางฝั่งของเว็บเซิร์ฟเวอร์เมื่อประมวลผลของการร้องขอที่ได้รับจากไคลเอนต์เสร็จแล้ว จะทำการส่งผลลัพธ์กลับไปยังไคลเอนต์ โดยจะต้องทำการส่งผ่านไปยังรีเวิร์สเว็บพรีอกซ์ก่อนเช่นกัน ซึ่งเมื่อรีเวิร์สเว็บพรีอกซ์ได้รับผลลัพธ์ที่จะส่งกลับไปยังไคลเอนต์ ก็จะนำไปตรวจสอบกับ reverse mapping และทำการเปลี่ยน URL และ HTTP header กลับเป็น URL ที่ใช้ในการติดต่อกับไคลเอนต์ ก่อนที่จะส่งผลลัพธ์นั้นกลับไปยังไคลเอนต์ ซึ่งไคลเอนต์จะมองเห็นว่าการร้องขอนั้นถูกตอบรับโดยรีเวิร์สเว็บพรีอกซ์ แต่แท้จริงแล้วถูกตอบโดยเว็บเซิร์ฟเวอร์

2.5.3 รีเวิร์สเว็บพร็อกซีแบบปลอดภัย (Secure Reverse Web Proxy)

เป็นการใช้งานรีเวิร์สเว็บพร็อกซีให้มีความปลอดภัยในการใช้งาน โดยทำการตรวจสอบการร้องขอที่เข้ามาก่อนที่จะส่งต่อไปให้กับเว็บเซิร์ฟเวอร์ ว่าการร้องขอนั้นตรงกับรูปแบบการโจมตีหรือไม่ หากพบว่าการร้องขอที่ตรงกับรูปแบบการโจมตีก็จะทำการสกัดการร้องขอนั้นไว้ โดยอาจจะทำการเก็บบันทึกลงล็อกไฟล์และทำการส่งค่า page ที่เหมือน page ปรกติเช่น page Error 404 This Page can not be found เป็นการตอบสนองที่เรียกว่า Silent Killer Operation



รูปที่ 2.5 การทำงานของรีเวิร์สเว็บพร็อกซีแบบปลอดภัย